Конфіденційно

Vision — аудит безпеки

Повторний аудит перед перенесенням у банківський контур

Коміт	`7b13af1` (гілка `main`)
Дата	5 листопада 2026
Скоуп	монорепо `nazarenkod/vision`: backend, prisma, frontend, CLI/MCP, sdk-java, scripts, infra, CI
Модель розгортання	внутрішній on-prem сервіс; кілька команд в одному інстансі; на тій самій машині, що й робочий VRT
Виконавець	Security engineer (аудит коду, SAST, сканери залежностей і образів, динамічний стенд)
Класифікація	Конфіденційно — лише для керівництва, ІБ та розробників

1. Резюме для керівництва

Vision — власний інструмент візуальних перевірок QA, який планують перенести у внутрішній банківський контур. Це **повторний** аудит: попередній (4 листопада 2026) закрив більшість проблем специфікаціями 040 та 042–045. Цей аудит додав те, чого раніше не було: статичний аналіз коду (SAST), сканер конфігурацій і образів, повну перевірку залежностей і динамічний стенд, на якому ключові вразливості відтворено наживо.

Загальний рівень ризику: ВИСОКИЙ. Базова гігієна помітно покращилась від попереднього аудиту (0 вразливих залежностей, секрети шифруються, ізоляція проєктів працює, заголовки й обробка помилок виправлені). Проте знайдено **одну критичну** вразливість, яку відтворено на стенді, і **шість високих**, серед яких автоматичне надсилання знімків банківських застосунків у зовнішній сервіс (Google Gemini) та кілька способів покласти сервіс одним запитом.

Critical 1 **High 6** **Medium 14** **Low 18** **Info 3**

Що змінилось від аудиту 2026-11-04. Підтверджено виправлення 10 з 15 попередніх знахідок (S-1, S-3, S-5, S-10, S-11 та частина S-7/S-8/S-9). П’ять — виправлені неповно (S-2, S-4, S-6, а також залишки S-7 і S-9). Три свідомі рішення (S-12, S-13, S-14) лишаються і для банку переоцінені. Головне: нові класи проблем, яких попередній аудит не шукав, — обчислювальні DoS при прийомі знімка, масове присвоєння полів через Prisma та автоматичний вихід даних у LLM.

Топ-5 ризиків:

1. **Ескалація editor→admin і крадіжка даних між командами** (VIS-SEC-001, Critical). Будь-який CI-ключ або editor однієї команди одним запитом `PATCH /builds` стає адміном усього інстансу й читає знімки інших команд. **Відтворено на стенді.**
2. **Автоматичний вихід даних банку в Google Gemini** (VIS-SEC-003, High). Якщо проєкт обрав VLM-рушій порівняння, скриншоти й тексти екранів ідуть у Gemini при кожному прийомі знімка, без людини й без вимикача на рівні інстансу.
3. **Відмова в обслуговуванні при прийомі знімка** (VIS-SEC-004, 005, High). Невеликий запит зупиняє API для всіх команд (аналіз доступності в головному потоці; зависання воркера через області ігнорування).
4. **Слабкі/спільні з продом секрети підпису** (VIS-SEC-002, High). Приймається `change-me`; інструкція радить узяти секрет робочого VRT — тоді токени Vision діють і на проді.
5. **Захоплення акаунта в режимі LDAP** (VIS-SEC-006, 007, High). Переприв’язка акаунта до чужої особи каталогу; вхід із порожнім паролем не відхиляється.

Вердикт готовності до банківського контуру: НЕ ГОТОВО. Перед перенесенням обов’язково виправити критичну знахідку (VIS-SEC-001) і всі високі (VIS-SEC-002…007), насамперед автоматичний вихід даних у Gemini та дві DoS. Після цього — повторна коротка перевірка. Решта (Medium/Low) — за планом на 30/90 днів. Частина змін змінює поведінку й потребує специфікації (цикл `/spec`); схема — лише додавальні міграції (ADR-0003).

2. Скоуп, методологія та обмеження

Предмет. Поточне дерево `main` (`7b13af1`). За рішенням власника історія git не розглядалась (її буде стерто при перенесенні). Робочий VRT, його база, контейнери й папка картинок — поза скоупом і не чіпались узагалі (правило 1, ADR-0002).

Методологія. Аудит за OWASP (Top 10 2021, ASVS). Етапи: (0) розвідка й модель загроз STRIDE; (1) автоматизовані сканування; (2) ручний аудит чотирма напрямами — автентифікація, авторизація й ізоляція, обробка вводу, зовнішні виклики й інфраструктура; (3) динамічне підтвердження на стенді. Кожну знахідку High/Critical перевірено вручну; результати сканерів переглянуто з позначенням false positive.

Інструменти (версії):

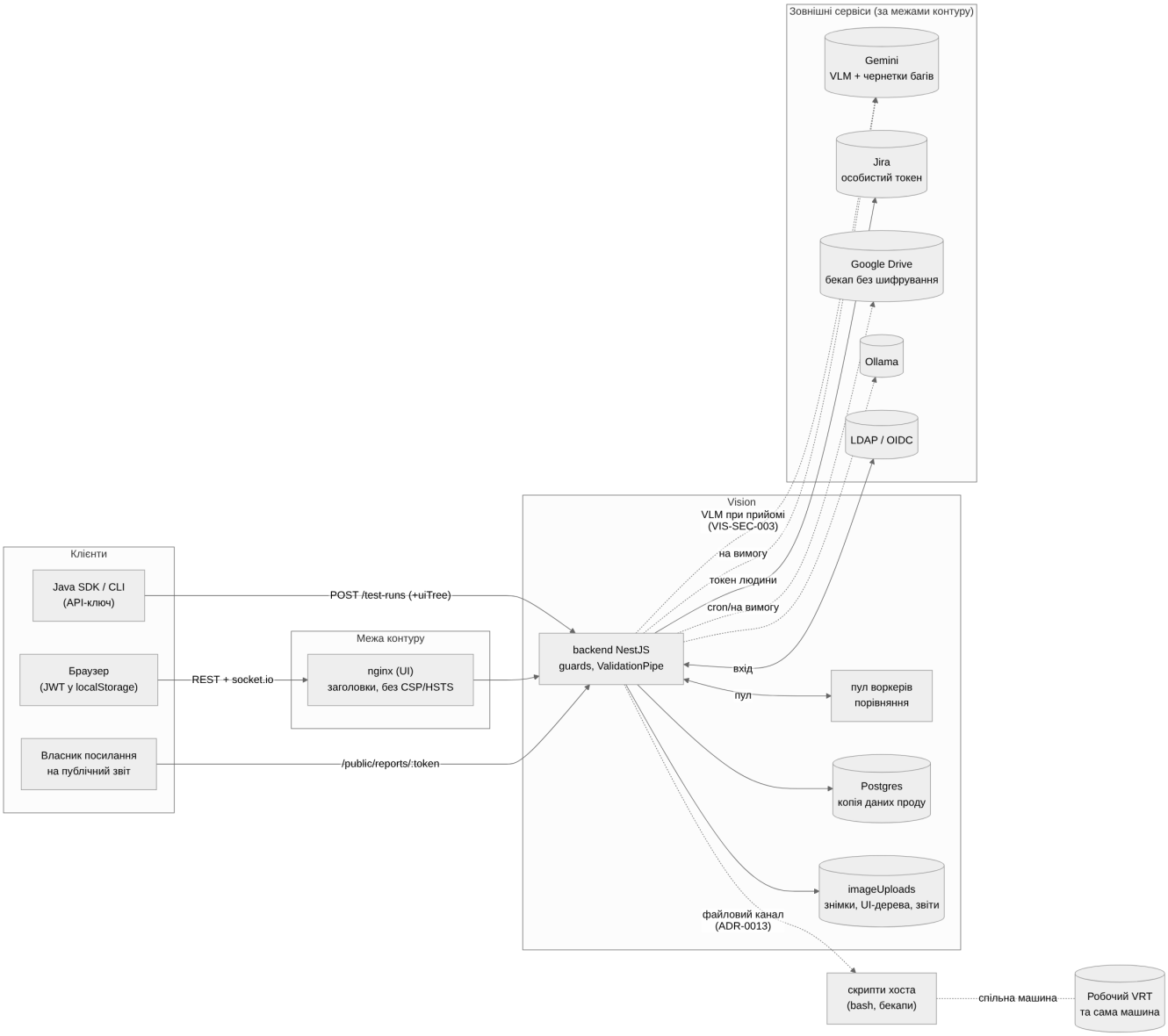
Напрям	Інструмент	Версія
Залежності	npm audit; osv-scanner; trivy fs	npm 10; osv-scanner 2.7.0; trivy (DB з mirror.gcr.io)
SAST	semgrep (локальні правила owasp/nodejs/ts/react/secrets/ java/python/dockerfile); bandit; shellcheck	semgrep 1.184.0; bandit 1.9.4; shellcheck 0.11.0
Секрети	gitleaks (режим файлів) + ручний grep	gitleaks 8.x
IaC / образи	trivy config; hadolint	trivy; hadolint 2.15.1
Ліцензії / SBOM	license-checker; trivy license; syft (CycloneDX)	—
Динаміка	нативний стенд: PostgreSQL 16, Node 24, API збірки `7b13af1`, лише синтетичні дані	—

Обмеження аудиту (важливо):

- **Без історії git** — за рішенням власника; сканування секретів лише по поточному дереву.
- **Без `trivy image`** — у середовищі немає демона Docker; образи статично не збирались. Оцінка образів — через `trivy config`, hadolint і читання Dockerfile. Пакети ОС усередині образів (базовий `node:24-bookworm-slim`) має прогнати сканер образів банку перед перенесенням.
- **Стенд нативний, не в Docker** — перевіряє логіку API, але не runtime-ізоляцію контейнерів і ліміти `compose`.
- **Gradle:** повний транзитивний граф SDK не зібрано (дзеркала Maven відповідали 429); перевірено прямі залежності й `trivy fs` (0 CVE).
- **LDAP/OIDC:** знахідки 006, 007, 020 виведені з коду — стенд каталогу/IdP не піднімався.
- **trufflehog** не встановився у цьому середовищі (конфлікт модулів Go); секрети покрито gitleaks і ручним grep.

3. Архітектура та модель загроз

Детально — у `audit/threat-model.md`. Нижче — діаграма потоків даних і межі довіри.



Активи: знімки й UI-дерева банківських застосунків (ПІБ, номери карток/рахунків, баланси); еталони; рішення команди; секрети (`JWT_SECRET`, `VISION_SECRET_KEY`, токени Jira, ключі Gemini, облікові Google Drive); хеші API-ключів; токени публічних звітів.

Межі довіри: SDK/CLI → API; браузер → nginx → API; API → Postgres/Redis/диск; **API → зовнішні сервіси (Gemini, Jira, Google Drive, Ollama, LDAP/OIDC) — вихід за межі контуру**; API ↔ скрипти хоста через файли; Vision ↔ робочий VRT на тій самій машині.

Ключовий висновок моделі: найбільші ризики — на межі «кілька команд в одному інстансі» (ізоляція, ескалація ролей) і на межі «контур → зовнішні сервіси» (автоматичний вихід даних у Gemini, незашифрований бекап у Google Drive). Повна матриця STRIDE — у `threat-model.md`.

4. Регресія попереднього аудиту (S-1…S-15)

Стан виправлень із `docs/security/audit-2026-11-04.md`. «Підтверджено» — виправлення на місці й з тестом; «неповно» — виправлено частково або лишився обхід; «рішення» — свідомо лишено (ADR).

#	Тема	Стан	Коментар
S-1	XXE / gzip-бомба в UI-дереві	**Підтверджено**	парсер без сутностей, ліміт 10 МиБ, fast-xml-parser 5.12. Але з’явились нові DoS поза S-1 (VIS-SEC-004, 014)
S-2	Токен Jira на чужий хост	**Неповно**	перевіряється лише hostname, не схема/порт/редиректи (VIS-SEC-008)
S-3	Секрети відкритим текстом у БД	**Підтверджено**	AES-256-GCM (044); залишок — без AAD, слабкий KDF (VIS-SEC-024)
S-4	Старт із відомими дефолтами	**Неповно**	`change-me/x` і пароль `123456` приймаються (VIS-SEC-002, 010)
S-5	Знімки без входу	**Підтверджено**	лише за підписом, nginx 404; залишок — безстрокове посилання (VIS-SEC-022, REQ-043-03)
S-6	Перебір / парольна політика	**Неповно**	ліміт лише за email; енумерація за таймінгом (VIS-SEC-033, 034)
S-7	Заголовки, Swagger, валідація	**Неповно**	CORS/Swagger виправлено; немає CSP/HSTS (VIS-SEC-011), ValidationPipe без whitelist (VIS-SEC-012)
S-8	Контейнери від root, TLS off	**Неповно**	`USER node` на місці; у dev `test:pw:install` досі вимикає TLS (VIS-SEC-029)
S-9	Postgres на хост	**Неповно**	у поставці виправлено; dev-compose досі публікує Postgres (VIS-SEC-019)

#	Тема	Стан	Коментар
S-10	Upstream-образи з Docker Hub	**Підтверджено**	власні образи за digest; `vrt-install.sh` і кореневий compose прибрано
S-11	Ізоляція проєктів	**Підтверджено**	ProjectAccess + глобальний інтерсептор + тест обходу; виняток — запис через VIS-SEC-001
S-12	`OIDC_TLS_NO_VERIFY`	**Рішення**	типово `false`; для банку — має бути заборонено, аналог `LDAP_TLS_NO_VERIFY` теж існує
S-13	JWT у localStorage	**Рішення**	для банку ризик підвищено: реальної CSP немає (VIS-SEC-011)
S-14	bcrypt cost 10	**Рішення**	прийнятно для нових; ризик — короткі успадковані паролі з копії VRT
S-15	Stack у відповідях помилок	**Підтверджено**	віддається лише `{statusCode,message,path}`; залишок — токени в логах (VIS-SEC-027)

Також перевірено специфікації: **040** (REQ-040-01…06 — на місці, крім неповного REQ-040-05), **042** (12 REQ; REQ-042-03/09 неповні через VIS-SEC-001), **043** (усі REQ відповідають коду), **044** (REQ-044-01…06, 09 — підтверджено; 07/08 неповні, VIS-SEC-008), **045** (підтверджено, крім REQ-045-08 — лише базові заголовки) та **035** (крім REQ-035-13 і 035-33 — неповні).

5. Зведена таблиця знахідок

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-001	Масове присвоєння в PATCH /builds/:id: ескалація editor→admin і крадіжка даних між командами	Critical	backend	S
VIS-SEC-002	Приймаються відомі/слабкі секрети підпису; DEPLOY.md радить секрет робочого VRT	High	backend	S
VIS-SEC-003	VLM-рушій автоматично надсилає знімки банку в Gemini при прийомі (напруга з правилом 6 / ADR-0007)	High	backend	M
VIS-SEC-004	Обчислювальна DoS: аналіз доступності UI-дерева блокує event loop для всіх команд	High	backend	M
VIS-SEC-005	Області ігнорування без меж координат зависають воркер порівняння без тайм-ауту	High	backend	S
VIS-SEC-006	Режим LDAP: будь-який користувач переприв’язує свій акаунт до чужої особи з каталогу	High	backend	M
VIS-SEC-007	Вхід через LDAP з порожнім паролем не відхиляється (ризик unauthenticated bind)	High	backend	S

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-008	Allowlist Jira перевіряє лише hostname: проходять http, будь-який порт і редиректи	Medium	backend	S
VIS-SEC-009	Немає відкликання сесій: logout, зміна пароля, блокування й зміна ролі не гасять JWT і сокет	Medium	backend	M
VIS-SEC-010	Дефолтний адмін із паролем 123456: нижче політики, друкується в лог, без примусової зміни	Medium	prisma	S
VIS-SEC-011	Немає CSP і HSTS; поставка публікує HTTP на всіх інтерфейсах без TLS-термінації	Medium	infra	M
VIS-SEC-012	Глобальний ValidationPipe без whitelist/ forbidNonWhitelisted/transform (системний корінь mass assignment)	Medium	backend	S
VIS-SEC-013	Бекап у Google Drive не шифрується і містить тексти екранів, email і токени публічних звітів	Medium	backend	M
VIS-SEC-014	Немає меж розміру файла й розмірів PNG: multer без limits, повне декодування в головному потоці	Medium	backend	S

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-015	ReDoS: регулярний вираз із text-селектора правила елемента виконується над текстами дерева в головному потоці	Medium	backend	M
VIS-SEC-016	AI_PROVIDER=none не вимикає зовнішній AI: особисті ключі Gemini і ключ проєкту діють далі	Medium	backend	M
VIS-SEC-017	Адмін задає пароль будь-якому акаунту (зокрема SSO/LDAP) і діє його токеном Jira	Medium	backend	M
VIS-SEC-018	Login CSRF / фіксація сесії: /login#token=<будь-який JWT> входить без state	Medium	frontend	S
VIS-SEC-019	Dev-compose у дереві: Postgres на 0.0.0.0 з postgres/postgres, ім’я контейнера збігається з продом, моки LDAP/OIDC	Medium	infra	S
VIS-SEC-020	SSO повертає роль editor тим, кого адмін понизив до guest; generic ‘admin’ у типовій групі	Medium	backend	M
VIS-SEC-021	Запобіжник агентів guard.py легко обходиться — правила 1–4 тримаються лише на дисципліні	Medium	ci	M

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-022	Підписане посилання на знімок безстрокове й не прив’язане до користувача	Low	backend	S
VIS-SEC-023	Підробка записів у лозі через назву перевірки	Low	backend	S
VIS-SEC-024	Шифрування секретів без AAD, KDF = один SHA-256; приймається вже зашифроване значення	Low	backend	S
VIS-SEC-025	Токени публічних звітів і токени Google Drive зберігаються відкрито	Low	backend	S
VIS-SEC-026	AI-ендпоінти на вимогу доступні ролі guest (платні виклики й дані проєкту)	Low	backend	S
VIS-SEC-027	У логи потрапляють відповіді моделі (тексти екранів) і URL із підписами/ токенами звітів	Low	backend	S
VIS-SEC-028	CLI пересилає заголовок apiKey при редиректі на інший хост/схему	Low	cli	S
VIS-SEC-029	test:pw:install вимикає перевірку TLS під час завантаження браузера	Low	frontend	S
VIS-SEC-030	CI: actions за тегами, не за SHA; не обмежено permissions GITHUB_TOKEN	Low	ci	S

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-031	Gradle wrapper 6.1 без distributionSha256Sum і без перевіреної контрольної суми jar	Low	sdk-java	S
VIS-SEC-032	Prompt injection: тексти екрана й назви перевірок у промптах; вердикт VLM сам ставить статус	Low	backend	S
VIS-SEC-033	Енумерація користувачів за часом відповіді входу	Low	backend	S
VIS-SEC-034	Ліміт входу лише за email: password spraying і блокування чужих акаунтів	Low	backend	S
VIS-SEC-035	Звільнені з каталогу/IdP зберігають доступ через API-ключ і локальний вхід	Low	backend	S
VIS-SEC-036	PUT /users записує email без нормалізації й перевірки дублікатів в іншому регістрі	Low	backend	S
VIS-SEC-037	Скрипти запускають образи за тегом з обліковими даними проду і –network host	Low	scripts	S
VIS-SEC-038	vision-safety.sh: .env.demo виконується як shell і може перевизначити закріплені VISION_*	Low	scripts	S

ID	Назва	Severity	Компонент	Зусилля
VIS-SEC-042	Тестові фікстури містять фотографію реальних людей (успадковано від upstream)	Low	backend	S
VIS-SEC-039	Образи не містять LICENSE і NOTICE (Apache-2.0 §4(a), (d))	Info	infra	S
VIS-SEC-040	JWT без явного алгоритму, issuer і audience	Info	backend	S
VIS-SEC-041	Editor може змінювати налаштування й видаляти будь-який доступний проєкт (зокрема ключ Gemini)	Info	backend	M

6. Детальні знахідки

Critical

Critical **VIS-SEC-001** · регресія S-7 **Масове присвоєння в PATCH /builds/:id: ескалація editor→admin і крадіжка даних між командами**

CWE / OWASP	CWE-915 · A08:2021-Software and Data Integrity Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H (9.6)`
Компонент / тип	backend · code · зусилля S · впевненість High

Місце	`backend/src/builds/dto/build-modify.dto.ts:1`
	`backend/src/builds/builds.service.ts:110`
	`backend/src/builds/builds.controller.ts:116`
	`backend/src/main.ts:42`

Опис. `ModifyBuildDto` — це TypeScript-інтерфейс без валідаторів, а глобальний `ValidationPipe` у main.ts:42 створений без `whitelist`. Тіло запиту повністю йде в `prisma.build.update({ data: modifyBuildDto })`. Через вкладені записи Prisma (`user.connect`/`user.update`, `projectId`) власник API-ключа будь-якої команди (роль editor) переписує чужі рядки.

Доказ. Відтворено на стенді (audit/raw/repro-001-patch-builds.txt): editor-ключ alice (доступ лише до Team A) → PATCH /builds/<b> {"user":{"connect":{"email":"alice"}}} 200, потім {"user":{"update":{"role":"admin"}}} 200; GET /users/all зі старим JWT alice → 200 (було 403), /users/me role=admin. Окремо PATCH {"projectId":"<Team B>"} переносить збірку зі знімками банківського застосунку в чужий проєкт — bob (Team B) починає її бачити.

Вплив. Будь-який CI-ключ або editor однієї команди банку стає admin всього інстансу: читає/змінює всі проєкти, скидає паролі й API-ключі, видаляє акаунти, краде знімки й UI-дерева (ПІБ, номери карток) інших команд. Повний обхід ізоляції 042 і рольової моделі.

Рекомендація. `new ValidationPipe({ whitelist: true, forbidNonWhitelisted: true, transform: true })` у main.ts; зробити `ModifyBuildDto` класом з `@IsOptional()`/`@IsString()`/`@IsBoolean()` лише для `ciBuildId`,`isRunning`. Сервіс має приймати лише ці поля (явний вибір, не весь DTO).

Пов’язано	S-7; спека 042 REQ-042-03/09; правило 7

High

High VIS-SEC-002 · регресія S-4 Приймаються відомі/слабкі секрети підпису; DEPLOY.md радить секрет робочого VRT

CWE / OWASP	CWE-1392 · A07:2021-Identification and Authentication Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:N (9.3)`
Компонент / тип	backend · config · зусилля S · впевненість High

Місце	`backend/src/main.ts:29-34`
	`backend/src/shared/secret-box.ts:43-53`
	`backend/src/shared/secret-box.spec.ts:25`
	`docker-compose.demo.yml`
	`DEPLOY.md:108`

Опис. Старт перевіряє лише, що `JWT_SECRET` і `VISION_SECRET_KEY` непорожні; значення `change-me` чи `x` приймаються (тест secret-box.spec.ts:25 це закріплює). Приклади середовища містять `change-me`. DEPLOY.md радить узяти секрет робочого VRT — тоді JWT Vision дійсні й на проді (порушення правила 1).

Доказ. main.ts:29-34 викликає serverSecretKey() лише на непорожність; .env*-приклади з `change-me`; DEPLOY.md:108.

Вплив. Якщо оператор не змінив JWT_SECRET, будь-хто підписує собі JWT адміна. Спільний із продом секрет дає токени, дійсні на робочому VRT.

Рекомендація. Відмовлятися стартувати, якщо секрет у чорному списку відомих значень або коротший за N; вимагати різні секрети для Vision і VRT; прибрати пораду з DEPLOY.md. Потребує мінімальної зміни bootstrap.

Пов’язано	S-4

High VIS-SEC-003 VLM-рушій автоматично надсилає знімки банку в Gemini при прийомі (напруга з правилом 6 / ADR-0007)

CWE / OWASP	CWE-200 · A01:2021-Broken Access Control
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:L/A:N (8.5)`
Компонент / тип	backend · code · зусилля M · впевненість High

Місце	`backend/src/test-runs/test-runs.service.ts:140-150`
	`backend/src/compare/compare.service.ts:62-63`
	`backend/src/compare/libs/vlm/vlm.service.ts:90-99`
	`backend/src/ai/gemini.service.ts:44`
	`docs/specs/035-admin-accounts/spec.md:192-193`

Опис. Якщо проєкт обрав рушій порівняння `vlm`, прийом знімка (POST /test-runs → calculateDiff → compareService.getDiff → getComparator → VlmService → GeminiService.generate) СИНХРОННО надсилає в Gemini три повні PNG (еталон, новий, diff). Вмикає будь-який editor проєкту; вимикача рівня інстансу немає, `AI_PROVIDER=none` на це не впливає. Вердикт моделі сам ставить статус (vlm.service.ts:98-99).

Доказ. Ланцюжок викликів у коді (див. location); спека 035:192-193 фіксує це як рішення власника 2026-11-02, що прямо суперечить правилу 6 «LLM ніколи при прийомі».

Вплив. Скриншоти й тексти екранів банківського застосунку (ПІБ, номери карток/рахунків, баланси) автоматично, без людини, залишають контур і йдуть у Google. Для банку це потенційний витік ПДн/банківської таємниці. Prompt injection у тексті екрана може приховати регресію.

Рекомендація. Для банку: вимикач рівня інстансу (hard off, напр. VISION_VLM_ALLOWED=false), що перекриває вибір проєкту; явне погодження ІБ на кожен проєкт із VLM; ніколи не дозволяти вердикту моделі самому затверджувати. Зміна поведінки — потребує специфікації (/spec).

Пов’язано	правило 6, ADR-0007, ADR-0020, спека 035

High VIS-SEC-004 Обчислювальна DoS: аналіз доступності UI-дерева блокує event loop для всіх команд

CWE / OWASP	CWE-400 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:N/A:H (7.7)`
Компонент / тип	backend · code · зусилля M · впевненість High

Місце	`backend/src/test-runs/test-runs.service.ts:144`
	`backend/src/ui-tree/ui-tree.service.ts:352`
	`backend/src/a11y/a11y.rules.ts:238-241`
	`backend/src/a11y/contrast.ts:26,49`

Опис. На шляху прийому `analyzeUiTree` синхронно викликає `findViolations`, яка для кожного текстового вузла рахує контраст, семплюючи до MAX_SAMPLES=40000 пікселів (contrast.ts). Усе синхронно в головному потоці, без воркера. Дерево обмежене лише 10 МиБ після розпакування — це десятки тисяч вузлів.

Доказ. Статично підтверджено (audit/raw/repro-003-ignore-areas.txt): intake→analyzeUiTree(test-runs.service.ts:144)→findViolations (синхронно). Вартість ~O(N_textual×40000). Поправка до оцінки агента: checkDuplicateLabels лінійний, не квадратичний. Живий payload не запускався.

Вплив. Один невеликий після стиснення запит від CI будь-якої команди зупиняє API для всіх команд інстансу на секунди-десятки секунд (event loop зайнятий). Поруч робочий VRT на тій самій машині — спільний CPU.

Рекомендація. Винести аналіз доступності у воркер-пул із тайм-аутом; обмежити кількість вузлів дерева і сумарну площу контрастних боксів; відхиляти дерева понад розумну кількість вузлів. Потребує специфікації (зміна поведінки прийому).

Пов’язано	спека 040

High VIS-SEC-005 Області ігнорування без меж координат зависають воркер порівняння без тайм-ауту

CWE / OWASP	CWE-400 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:N/I:N/A:H (7.7)`
Компонент / тип	backend · code · зусилля S · впевненість High

Місце	`backend/src/compare/utils/index.ts:14-26`
	`backend/src/test-runs/dto/ignore-area.dto.ts:5-19`
	`backend/src/compare/diff-worker-pool.ts:52-70`

Опис. `applyIgnoreAreas` ітерує від `area.y/area.x` без нижньої межі; `IgnoreAreaDto` перевіряє лише `@IsNumber`. Величезні від'ємні координати з великими width/height дають майже нескінченний цикл. Пул воркерів порівняння не має тайм-ауту завдання. Область зберігається й застосовується до кожного наступного знімка перевірки.

Доказ. Офлайн-замір скомпільованої функції (repro-003): applyIgnoreAreas(PNG 100×100, {x:-1e9,y:-1e9,width:2e9,height:2e9}) не повертається за 5 с (timeout).

Вплив. Кілька запитів editor-а зупиняють увесь пул порівняння — завантаження знімків стоїть у всіх проєктах; перезапуск не допомагає, бо отруєна область збережена.

Рекомендація. Обмежувати координати межами зображення при валідації і в applyIgnoreAreas (Math.max(0,...)); тайм-аут на завдання воркера. Потребує специфікації.

High VIS-SEC-006 Режим LDAP: будь-який користувач переприв’язує свій акаунт до чужої особи з каталогу

CWE / OWASP	CWE-287 · A07:2021-Identification and Authentication Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N (9.3)`
Компонент / тип	backend · code · зусилля M · впевненість Medium
Місце	`backend/src/users/ldap/ldapusers.service.ts:113-121`

Опис. `LdapUsersService.update` бере email з тіла PUT /users і записує в акаунт того, хто викликає, дані знайденої в каталозі людини. Нападник ставить собі email колеги; коли справжня людина вперше входить через LDAP, вона потрапляє в акаунт нападника.

Доказ. ldapusers.service.ts:113-121 (аналіз коду; стенда LDAP не піднімали).

Вплив. Захоплення акаунта: підміна особи в журналі рішень, доступ нападника через заздалегідь виданий API-ключ, токен Jira жертви в руках нападника.

Рекомендація. Не дозволяти змінювати email у LDAP-режимі; прив'язка лише за незмінним ідентифікатором каталогу (objectGUID/sAMAccountName), не за email із тіла запиту. Потребує специфікації.

Пов’язано	спека 045, ADR-0025

High VIS-SEC-007 Вхід через LDAP з порожнім паролем не відхиляється (ризик unauthenticated bind)

CWE / OWASP	CWE-287 · A07:2021-Identification and Authentication Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N (8.1)`
Компонент / тип	backend · code · зусилля S · впевненість Medium
Місце	`backend/src/users/ldap/ldapusers.service.ts:141`

Опис. DTO входу перевіряє лише `@IsString()`; далі `bind(dn, '')` без перевірки непорожності пароля. Багато LDAP/AD за замовчуванням трактують bind із порожнім паролем як успішний анонімний bind.

Доказ. ldapusers.service.ts:141 (аналіз коду). Чи ldapts 9.2.0 сам відкидає порожній пароль — не перевірено.

Вплив. На типовому AD без DenyUnauthenticatedBind — вхід у будь-який акаунт каталогу без пароля.

Рекомендація. Відхиляти порожній/пробільний пароль до bind; увімкнути відмову від unauthenticated bind. Потребує специфікації.

Пов’язано	спека 045

Medium

Medium VIS-SEC-008 · регресія S-2 **Allowlist Jira перевіряє лише hostname: проходять http, будь-який порт і редиректи**

CWE / OWASP	CWE-918 · A10:2021-Server-Side Request Forgery
CVSS	`CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:N (6.8)`
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/a11y/jira-hosts.ts:15-22` `backend/src/a11y/jira.client.ts:102`

Опис. `isAllowedJiraUrl` звіряє лише `new URL(url).hostname`. Проходять `http://` (токен відкритим текстом), будь-який порт, інші схеми. `fetch` іде за редиректами; Node прибирає Authorization при зміні хоста, але тіло POST з вкладеннями-скриншотами при 307 пересилається, а частина відповіді внутрішнього сервісу повертається користувачу (SSRF).

Доказ. jira-hosts.ts:15-22 (лише hostname); jira.client.ts:102 fetch з редиректами.

Вплив. Editor скеровує особисті токени Jira й скриншоти банку на http або внутрішній сервіс; обмежена SSRF у мережу банку / на localhost (робочий VRT).

Рекомендація. Вимагати https, звіряти host+port, заборонити редиректи (`redirect: 'error'`) або повторно валідувати кінцевий URL; заборонити приватні IP.

Пов’язано	S-2, спека 044 REQ-044-07/08

Medium VIS-SEC-009 **Немає відкликання сесій: logout, зміна пароля, блокування й зміна ролі не гасять JWT і сокет**

CWE / OWASP	CWE-613 · A07:2021-Identification and Authentication Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N (7.1)`
Компонент / тип	backend · code · зусилля M · впевненість High
Місце	`backend/src/auth` `backend/src/shared/events/events.gateway.ts`

Опис. JWT містить лише email; немає чорного списку/версії токена. Logout лише в браузері. Зміна пароля не гасить старі токени (підтверджено на стенді). `isActive` ніде не перевіряється — заблокувати акаунт без видалення неможливо. Відкрите сокет-з'єднання отримує події до exp навіть після видалення акаунта чи зняття ролі.

Доказ. Стенд (repro-002): PUT /users/password → старий JWT далі дає 200 на /users/me. Сокет leaveProject лише при revoke доступу.

Вплив. Вкрадений/виданий до звільнення токен або API-ключ діє до доби; неможливо швидко відрізати скомпрометований акаунт — критично для банку.

Рекомендація. Версія токена в User (додавальна колонка, ADR-0003), перевірка при кожному запиті й при рукостисканні сокета; інвалідація при зміні пароля/ролі/блокуванні. Потребує специфікації.

Пов’язано	S-13; спека 032/045

Medium VIS-SEC-010 · регресія S-4 **Дефолтний адмін із паролем 123456: нижче політики, друкується в лог, без примусової зміни**

CWE / OWASP	CWE-798 · A07:2021-Identification and Authentication Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N (8.1)`
Компонент / тип	prisma · config · зусилля S · впевненість High
Місце	`backend/prisma/seed.ts:43` `docker-compose.demo.yml:129`

Опис. На порожній базі seed створює admin@vision.local з паролем за замовчуванням (у demo — 123456), коротшим за політику 12 символів, і друкує факт у лог. Примусової зміни при першому вході немає (свідомо, рішення власника).

Доказ. seed.ts:43; demo compose DEFAULT_USER_PASSWORD; лог seed на стенді друкує email і пароль.

Вплив. Якщо дефолт не змінено до першого доступу в мережу банку — повний адмін-доступ за відомим паролем.

Рекомендація. Генерувати випадковий пароль, не друкувати його, вимагати зміну при першому вході; demo-пароль не тягнути в поставку. Примусова зміна — потребує специфікації.

Пов’язано S-4, спека 035

Medium VIS-SEC-011 · регресія S-7 **Немає CSP і HSTS; поставка публікує HTTP на всіх інтерфейсах без TLS-термінації**

CWE / OWASP	CWE-693 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:H/I:H/A:N (6.8)`
Компонент / тип	infra · config · зусилля M · впевненість High

Місце	`backend/src/security.ts`
	`frontend/nginx/default.conf`
	`docker-compose.demo.yml:31,106`

Опис. Власний middleware і nginx інтерфейсу ставлять X-Frame-Options/X-Content-Type-Options/ Referrer-Policy, але НЕ CSP і НЕ HSTS (підтверджено на стенді для API). docker-compose.demo.yml публікує UI 18080 і API 14200 на 0.0.0.0 по HTTP; TLS-термінації в поставці немає, DEPLOY.md її не описує (конфіг ssl/ з TLS на 5000 у compose не задіяний).

Доказ. Стенд: GET /health віддає X-Frame-Options/Referrer-Policy, але без Content-Security-Policy і Strict-Transport-Security. demo compose: `18080:8080`, `14200:3000` без 127.0.0.1.

Вплив. Відсутність CSP робить ризик S-13 (JWT у localStorage) реальним: будь-який XSS краде сесію. HTTP на всіх інтерфейсах у банку — перехоплення токенів і знімків.

Рекомендація. Додати CSP (default-src 'self') і HSTS; у поставці термінувати TLS (reverse-proxy) і прив'язувати порти до 127.0.0.1 за проксі; описати TLS у DEPLOY.md.

Пов’язано S-7, S-13

Medium VIS-SEC-012 · регресія S-7 Глобальний ValidationPipe без whitelist/forbidNonWhitelisted/transform (системний корінь mass assignment)

CWE / OWASP	CWE-915 · A08:2021-Software and Data Integrity Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:H/A:N (6.5)`
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/main.ts:42`

Опис. `new ValidationPipe()` без опцій: невідомі поля тіла не відсікаються в усьому API. Захист від mass assignment тримається лише на ручному виборі полів у кожному сервісі; VIS-SEC-001 — відомий інстанс, але ризик системний.

Доказ. main.ts:42.

Вплив. Будь-який ендпоінт, що передає DTO в Prisma, потенційно вразливий до підміни полів.

Рекомендація. `new ValidationPipe({ whitelist: true, forbidNonWhitelisted: true, transform: true })` і перевести решту DTO-інтерфейсів на класи з валідаторами.

Пов’язано	S-7, VIS-SEC-001

Medium VIS-SEC-013 Бекап у Google Drive не шифрується і містить тексти екранів, email і токени публічних звітів

CWE / OWASP	CWE-311 · A02:2021-Cryptographic Failures
CVSS	`CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:N/A:N (6.8)`
Компонент / тип	backend · process · зусилля M · впевненість High

Місце	`backend/src/backups`
	`scripts/vision-backup.sh:14`
	`docs/decisions/0012-backups-without-secrets.md`

Опис. Дамп бекапу анулює секретні колонки (jiraToken, geminiApiKey), але залишає тексти екранів у збережених UI-деревах, email співробітників і діючі токени публічних звітів (256-біт посилання без входу). Бекап вивантажується в Google Drive без наскрізного шифрування (ADR-0012).

Доказ. vision-backup.sh:14 (анулювання секретів); схема ReportLink.token; ADR-0012.

Вплив. Для банку: банківські дані екранів і діючі анонімні посилання на звіти залишають контур у Google без шифрування.

Рекомендація. Для контуру — вимкнути Google Drive (внутрішнє сховище) або шифрувати бекап перед вивантаженням; відкликати/виключити токени звітів із бекапу. Рішення власника (ADR-0012) — переоцінити для банку.

Пов’язано	ADR-0012, S-?

Medium VIS-SEC-014 · регресія S-1 Немає меж розміру файла й розмірів PNG: multer без limits, повне декодування в головному потоці

CWE / OWASP	CWE-400 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H (6.5)`
Компонент / тип	backend · code · зусилля S · впевненість Medium
Місце	`backend/src/test-runs/test-runs.controller.ts:374` `backend/src/static/hdd/hdd.service.ts:48-55`

Опис. `FileInterceptor('image')` без `limits`; вміст не перевіряється на PNG; розміри з IHDR не обмежуються, декодування повне (pngjs) у головному потоці. Малий файл із великими заявленими розмірами (напр. 30000×30000) розпухає в пам'яті.

Доказ. test-runs.controller.ts:374 (без limits); hdd.service.ts:48-55 (повне декодування). Живий payload не запускався.

Вплив. Вичерпання пам'яті процесу API одним запитом; відмова для всіх команд.

Рекомендація. `FileInterceptor('image',{limits:{fileSize}})`; перевірка сигнатури PNG; межа ширини×висоти до декодування; декодувати у воркері.

Пов’язано	S-1, спека 040

Medium VIS-SEC-015 ReDoS: регулярний вираз із text-селектора правила елемента виконується над текстами дерева в головному потоці

CWE / OWASP	CWE-1333 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:N/I:N/A:H (6.5)`
Компонент / тип	backend · code · зусилля M · впевненість Medium
Місце	`backend/src/ui-tree/comparison-inputs.ts:105-120` `frontend/src/components/TestDetailsDialog/TestDetailsModal.tsx:660`

Опис. Селектор `text:/.../` компілюється в RegExp без обмеження довжини/складності й застосовується до текстів дерева в головному потоці. Вкладені квантифікатори + майже-збіг дають катастрофічний бектрекінг.

Доказ. comparison-inputs.ts:116 new RegExp з даних editor-а; застосування в compare-шляху.

Вплив. Editor зупиняє порівняння/рев'ю одним правилом + відповідним деревом.

Рекомендація. Обмежити довжину селектора; використати безпечний движок або тайм-аут; винести у воркер.

Пов’язано	ADR-0021

Medium VIS-SEC-016 AI_PROVIDER=none не вимикає зовнішній AI: особисті ключі Gemini і ключ проєкту діють далі

CWE / OWASP	CWE-16 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:N/A:N (7.7)`
Компонент / тип	backend · code · зусилля M · впевненість High
Місце	`backend/src/ai/ai.service.ts` `docs/decisions/0020-personal-gemini-keys.md`

Опис. Налаштування `AI_PROVIDER=none` стосується лише чернеток багів на вимогу, але не перекриває особисті ключі Gemini користувачів і ключ Gemini проєкту (VLM-рушій, VIS-SEC-003). Єдиного вимикача зовнішнього AI на рівні інстансу немає.

Доказ. ai.service.ts (гілки провайдерів); ADR-0020.

Вплив. Адмін банку не може однією настройкою гарантувати, що жодні дані не підуть у Gemini.

Рекомендація. Жорсткий вимикач рівня інстансу, що перекриває і VLM-рушій, і особисті/проєктні ключі. Потребує специфікації.

Пов’язано	VIS-SEC-003, ADR-0007/0020

Medium VIS-SEC-017 Адмін задає пароль будь-якому акаунту (зокрема SSO/LDAP) і діє його токеном Jira

CWE / OWASP	CWE-269 · A01:2021-Broken Access Control
CVSS	`CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:U/C:H/I:H/A:N (6.0)`
Компонент / тип	backend · code · зусилля M · впевненість Medium
Місце	`backend/src/users/users.controller.ts:189`

Опис. PUT /users/:id/password дозволяє адміну поставити локальний пароль будь-якому акаунту, навіть створеному через SSO/LDAP, і увійти ним локально — діючи його особистим токеном Jira (обхід духу REQ-035-33 «лише особисті токени»).

Доказ. users.controller.ts:189 (admin-only, без заборони для зовнішніх акаунтів).

Вплив. Адмін підміняє особу співробітника в Jira й журналі рішень; немає розділення обов'язків.

Рекомендація. Заборонити локальний пароль для SSO/LDAP-акаунтів; аудит-лог адмінських дій над акаунтами. Потребує специфікації.

Пов’язано	REQ-035-33

Medium VIS-SEC-018 Login CSRF / фіксація сесії: /login#token=<будь-який JWT> входить без state

CWE / OWASP	CWE-352 · A01:2021-Broken Access Control
CVSS	`CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:H/A:N (6.3)`
Компонент / тип	frontend · code · зусилля S · впевненість Medium
Місце	`frontend/src/pages/LoginPage.tsx:25-48`

Опис. Сторінка входу приймає JWT із фрагмента URL (#token=) без перевірки state/прив'язки. Зловмисник підсовує жертві посилання з власним токеном і фіксує її сесію під підконтрольним акаунтом.

Доказ. LoginPage.tsx:25-48.

Вплив. Жертва непомітно працює в акаунті нападника (завантажує туди знімки) або нападник підставляє токен, щоб перехопити дії.

Рекомендація. Не приймати токен із URL-фрагмента; лише через контрольований OIDC-redirect зі state/nonce.

Пов’язано	спека 045

Medium VIS-SEC-019 · регресія S-9 Dev-compose у дереві: Postgres на 0.0.0.0 з postgres/postgres, ім'я контейнера збігається з продом, моки LDAP/OIDC

CWE / OWASP	CWE-1188 · A05:2021-Security Misconfiguration
CVSS	`CVSS:3.1/AV:A/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H (8.0)`
Компонент / тип	infra · config · зусилля S · впевненість High

Місце	`backend/docker-compose.yml:48,56`
	`backend/docker-compose.ldap.yml`
	`backend/docker-compose.oidc.yml`

Опис. Dev-compose публікує Postgres `${POSTGRES_PORT}:5432` на всіх інтерфейсах з postgres/postgres і `container_name: postgres` — те саме ім'я, що в робочого VRT (ризик колізії на спільній машині, правило 1). Моки LDAP/OIDC із відомими секретами. Якщо dev-compose випадково потрапить у поставку — відкрита база.

Доказ. backend/docker-compose.yml:48 (container_name: postgres), :56 (${POSTGRES_PORT}:5432).

Вплив. На спільній із продом машині запуск dev-compose може зіткнутися з контейнером VRT; відкритий Postgres із дефолтним паролем у мережі банку.

Рекомендація. Прив'язати порт до 127.0.0.1, унікальне ім'я контейнера, явно виключити dev-compose з поставки (вони лише для розробки); demo compose вже не публікує Postgres.

Пов’язано	S-9

Medium VIS-SEC-020 SSO повертає роль editor тим, кого адмін понизив до guest; generic 'admin' у типовій групі

CWE / OWASP	CWE-266 · A01:2021-Broken Access Control
CVSS	`CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N (7.4)`
Компонент / тип	backend · code · зусилля M · впевненість Medium
Місце	`backend/src/users/oidc`

Опис. При вході через OIDC роль перераховується з груп IdP і перетирає локально понижену (admin→guest повертається до editor). Типове `OIDC_ADMIN_VALUES` містить загальну назву групи `admin`, що легко збігається з чужою групою IdP.

Доказ. Логіка мапінгу ролей OIDC (users/oidc).

Вплив. Понижений чи обмежений співробітник повертає собі права наступним входом; надто широке типове значення дає адміна зайвим людям.

Рекомендація. Локальне пониження має мати пріоритет або блокувати підвищення; типове OIDC_ADMIN_VALUES лишити порожнім і вимагати явного налаштування.

Пов’язано	спека 045/035

Medium VIS-SEC-021 Запобіжник агентів guard.py легко обходиться — правила 1–4 тримаються лише на дисципліні

CWE / OWASP	CWE-807 · A04:2021-Insecure Design
CVSS	`CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:L/I:H/A:H (7.3)`
Компонент / тип	ci · process · зусилля M · впевненість High
Місце	`.claude/hooks/guard.py`

Опис. Перевірка аргументів у guard.py обходиться: `docker --context … compose`, `bash -c '…'`, `docker container stop`, `docker exec … dropdb`, `git push --force vision main`. Хук — зручність, не бар'єр безпеки; непорушні правила 1–4 (захист робочого VRT і бази) тримаються на дисципліні агента.

Доказ. Пряма перевірка функції check() (scratchpad/agent-D/g.py).

Вплив. На спільній із продом машині агент (або скомпрометований агентський процес) може зачепити робочий VRT попри хук.

Рекомендація. Не покладатися на guard.py як на контроль безпеки; ізолювати права Docker/БД агента на рівні ОС (окремий користувач, обмежений доступ до сокета Docker, read-only до прод-даних).

Пов’язано	ADR-0002/0027, правила 1–4

Low

Low VIS-SEC-022 · регресія S-5 Підписане посилання на знімок безстрокове й не прив'язане до користувача

CWE / OWASP	CWE-200 · A05:2021-Security Misconfiguration
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/static/file-links.ts:5-9,29` `backend/src/static/static.controller.ts:16`

Опис. HMAC-підпис рахується лише від імені файла: посилання діє вічно й будь-хто з ним бачить знімок; потрапивши в Jira/лог/історію браузера, не відкликається. Це закріплено в REQ-043-03 як рішення.

Доказ. file-links.ts:29 (підпис лише від імені).

Вплив. Обмежений; див. опис.

Рекомендація. Додати строк дії й прив'язку до користувача/сесії; переоцінити REQ-043-03 для банку.

Low VIS-SEC-023 Підробка записів у лозі через назву перевірки

CWE / OWASP	CWE-117 · A09:2021-Security Logging and Monitoring Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/ui-tree/ui-tree.service.ts:269-271`

Опис. Назва перевірки з недовіреного джерела логується без екранування переносів рядків — можна вписати фальшиві рядки логу (log injection).

Доказ. ui-tree.service.ts:270.

Вплив. Обмежений; див. опис.

Рекомендація. Екранувати переноси в логованих значеннях; структуроване логування.

Low VIS-SEC-024 · регресія S-3 Шифрування секретів без AAD, KDF = один SHA-256; приймається вже зашифроване значення

CWE / OWASP	CWE-327 · A02:2021-Cryptographic Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/shared/secret-box.ts:12-23,34`

Опис. AES-256-GCM без AAD; ключ — простий SHA-256 від рядка без перевірки довжини/ентропії. `keepConfigSecrets` приймає від клієнта вже зашифроване значення з префіксом enc:v1: (можлива підстава чужого шифротексту).

Доказ. secret-box.ts:12 (sha256 KDF), :19 (без AAD). semgrep gcm-no-tag-length.

Вплив. Обмежений; див. опис.

Рекомендація. Додати AAD (контекст поля), вимагати достатню ентропію ключа, не приймати enc:-значення ззовні.

Low VIS-SEC-025 Токени публічних звітів і токени Google Drive зберігаються відкрито

CWE / OWASP	CWE-312 · A02:2021-Cryptographic Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/prisma/schema.prisma (ReportLink.token)` `backend/src/backups/drive-auth.ts`

Опис. ReportLink.token (256-біт анонімний доступ) і облікові дані Google Drive лежать у БД/файлі відкритим текстом; дамп БД або бекап дає анонімний доступ до звітів.

Доказ. schema ReportLink; drive-auth.ts.

Вплив. Обмежений; див. опис.

Рекомендація. Зберігати лише хеш токена звіту (перевірка за хешем); токени Drive — через secret-box.

Low VIS-SEC-026 AI-ендпоінти на вимогу доступні ролі guest (платні виклики й дані проєкту)

CWE / OWASP	CWE-285 · A01:2021-Broken Access Control
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/ai`

Опис. Частина AI-ендпоінтів (group-summary, a11y-labels, перелік report-link) доступна guest; guest запускає платні виклики моделі інстансу з даними проєкту.

Доказ. endpoints.md (guest-доступні AI-маршрути).

Вплив. Обмежений; див. опис.

Рекомендація. Обмежити щонайменше editor; окремий ліміт на guest.

Low VIS-SEC-027 У логи потрапляють відповіді моделі (тексти екранів) і URL із підписами/токенами звітів

CWE / OWASP	CWE-532 · A09:2021-Security Logging and Monitoring Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/ai` `backend/src (Logger)`

Опис. Debug/логи містять відповіді VLM (тексти банківських екранів) і повні URL із підписами знімків та токенами публічних звітів.

Доказ. grep Logger/console у ai та static.

Вплив. Обмежений; див. опис.

Рекомендація. Не логувати тіла відповідей моделі й повні підписані URL; редагувати токени.

Low VIS-SEC-028 CLI пересилає заголовок apiKey при редиректі на інший хост/схему

CWE / OWASP	CWE-200 · A07:2021-Identification and Authentication Failures
Компонент / тип	cli · code · зусилля S · впевненість High
Місце	`frontend/public/cli/vision.py:102,212`

Опис. urllib за замовчуванням іде за редиректами й повторно шле заголовок apiKey; зловмисний сервер (або MITM на http) перенаправляє на свій хост і збирає ключі.

Доказ. vision.py:102,212 (urlopen без заборони редиректів); bandit B310.

Вплив. Обмежений; див. опис.

Рекомендація. Заборонити редиректи або не пересилати apiKey на інший origin; вимагати https.

Low VIS-SEC-029 · регресія S-8 test:pw:install вимикає перевірку TLS під час завантаження браузера

CWE / OWASP	CWE-295 · A05:2021-Security Misconfiguration
Компонент / тип	frontend · code · зусилля S · впевненість High
Місце	`frontend/package.json:48`

Опис. `NODE_TLS_REJECT_UNAUTHORIZED=0 npx playwright install` — MITM під час завантаження браузера може підмінити бінарник. Лише dev-скрипт, у поставку не йде.

Доказ. frontend/package.json:48.

Вплив. Обмежений; див. опис.

Рекомендація. Прибрати прапорець; у контурі — корпоративний CA через NODE_EXTRA_CA_CERTS.

Low VIS-SEC-030 CI: actions за тегами, не за SHA; не обмежено permissions GITHUB_TOKEN

CWE / OWASP	CWE-1357 · A08:2021-Software and Data Integrity Failures
Компонент / тип	ci · code · зусилля S · впевненість High
Місце	`.github/workflows/docs.yml:12,13`

Опис. actions/checkout@v4 і setup-python@v5 закріплені тегом, не SHA (ризик підміни тега); job без явного `permissions:` (успадковує широкі права токена).

Доказ. docs.yml:12-13; semgrep github-actions-mutable-action-tag.

Вплив. Обмежений; див. опис.

Рекомендація. Закріпити actions за SHA; додати `permissions: contents: read`.

Low VIS-SEC-031 Gradle wrapper 6.1 без distributionSha256Sum і без перевіреної контрольної суми jar

CWE / OWASP	CWE-494 · A08:2021-Software and Data Integrity Failures
Компонент / тип	sdk-java · code · зусилля S · впевненість Medium
Місце	`sdk-java/gradle/wrapper/gradle-wrapper.properties` `sdk-java/gradle/wrapper/gradle-wrapper.jar`

Опис. У gradle-wrapper.properties немає distributionSha256Sum; дистрибутив Gradle завантажується без перевірки цілісності. Контрольна сума gradle-wrapper.jar (96f793a1…f4b6) не звірена з офіційною (мережа заблокувала завантаження офіційної суми).

Доказ. gradle-wrapper.properties (без distributionSha256Sum).

Вплив. Обмежений; див. опис.

Рекомендація. Додати distributionSha256Sum; звірити jar з офіційним для версії; оновити застарілі плагіни (shadow 5.2.0, lombok 5.1.1).

Low VIS-SEC-032 Prompt injection: тексти екрана й назви перевірок у промптах; вердикт VLM сам ставить статус

CWE / OWASP	CWE-94 · A03:2021-Injection
Компонент / тип	backend · code · зусилля S · впевненість Medium
Місце	`backend/src/ai/gemini.service.ts` `backend/src/compare/libs/vlm/vlm.service.ts:98-99`

Опис. Тексти з UI-дерева й назви тестів потрапляють у промпт чернетки бага і VLM-порівняння; зловмисний текст на екрані може спотворити чернетку або (для VLM) вплинути на вердикт, який сам ставить статус ok.

Доказ. vlm.service.ts:98-99.

Вплив. Обмежений; див. опис.

Рекомендація. Не дозволяти вердикту моделі самому затверджувати; розділяти інструкції й дані в промпті; екранувати.

Low VIS-SEC-033 Енумерація користувачів за часом відповіді входу

CWE / OWASP	CWE-203 · A07:2021-Identification and Authentication Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/users`

Опис. Текст відповіді однаковий, але bcrypt виконується лише для наявного акаунта — час відповіді видає наявність email.

Доказ. Стенд (repro-002): nobody 3-7 мс vs bob 89-90 мс.

Вплив. Обмежений; див. опис.

Рекомендація. Виконувати фіктивний bcrypt для невідомих email (константний час).

Low VIS-SEC-034 · регресія S-6 Ліміт входу лише за email: password spraying і блокування чужих акаунтів

CWE / OWASP	CWE-307 · A07:2021-Identification and Authentication Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/users`

Опис. Ліміт 5/15хв рахується за email, не за IP. Один пароль проти багатьох акаунтів не обмежений; і навпаки — будь-хто анонімно блокує вхід відомого email на 15 хв (DoS).

Доказ. Стенд (repro-002): 6 хибних спроб → 429; правильний пароль з іншого X-Forwarded-For → 429.

Вплив. Обмежений; див. опис.

Рекомендація. Додати ліміт за IP (з коректним trust proxy) поряд з лімітом за акаунтом; не блокувати легітимного користувача.

Low VIS-SEC-035 Звільнені з каталогу/IdP зберігають доступ через API-ключ і локальний вхід

CWE / OWASP	CWE-613 · A07:2021-Identification and Authentication Failures
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/users`

Опис. API-ключ не має строку дії й не перевіряє стан акаунта в каталозі; після вимкнення в LDAP/IdP доступ через ключ (і локальний пароль, якщо заданий) лишається.

Доказ. Аналіз: немає перевірки isActive/каталогу при apiKey.

Вплив. Обмежений; див. опис.

Рекомендація. Перевіряти стан акаунта при кожному запиті; строк дії й ротація ключів.

Low VIS-SEC-036 PUT /users записує email без нормалізації й перевірки дублікатів в іншому регістрі

CWE / OWASP	CWE-706 · A04:2021-Insecure Design
Компонент / тип	backend · code · зусилля S · впевненість High
Місце	`backend/src/users/dbusers.service.ts:35`

Опис. Email записується як є; два акаунти з різним регістром однакового email можливі — плутанина в журналі рішень і при вході.

Доказ. dbusers.service.ts:35.

Вплив. Обмежений; див. опис.

Рекомендація. Нормалізувати email (lowercase) і забезпечити унікальність без урахування регістру (додавальний індекс).

Low VIS-SEC-037 Скрипти запускають образи за тегом з обліковими даними проду і –network host

CWE / OWASP	CWE-494 · A08:2021-Software and Data Integrity Failures
Компонент / тип	scripts · code · зусилля S · впевненість Medium
Місце	`scripts/demo-clone-from-prod.sh` `scripts/lib/vision-backup.sh`

Опис. Частина скриптів запускає образи за рухомим тегом і з –network host/обліковими даними проду; підміна тега або компрометація образу дає доступ у мережу/до даних проду.

Доказ. demo-clone-from-prod.sh; shellcheck SC2010 та ін.

Вплив. Обмежений; див. опис.

Рекомендація. Закріпити образи за digest; мінімізувати мережу; не передавати прод-креденшали у скрипти demo.

Low VIS-SEC-038 vision-safety.sh: .env.demo виконується як shell і може перевизначити закріплені VISION_*

CWE / OWASP	CWE-94 · A08:2021-Software and Data Integrity Failures
Компонент / тип	scripts · code · зусилля S · впевненість Medium
Місце	`scripts/lib/vision-safety.sh` `scripts/lib/vision-backup.sh`

Опис. Файли оточення підключаються як shell (source); спеціально сформований .env.demo може перевизначити змінні-запобіжники або виконати код.

Доказ. shellcheck SC2148 (vision-safety.sh без shebang); патерн source .env.

Вплив. Обмежений; див. опис.

Рекомендація. Парсити .env без виконання (grep/export лише KEY=VALUE); права 600 на .env.

Low VIS-SEC-042 · регресія L-2 Тестові фікстури містять фотографію реальних людей (успадковано від upstream)

CWE / OWASP	CWE-359 · A04:2021-Insecure Design
Компонент / тип	backend · code · зусилля S · впевненість High

Місце	`backend/test/image.png`
	`backend/test/image_edited.png`
	`backend/test/image_edited_2.png`

Опис. Тестові знімки backend/test/image*.png (360×360) — фотографія реальних упізнаваних людей, успадкована від upstream VRT, а не синтетичний контент. Не екран банку, але чужі персональні дані (зображення осіб) у дереві.

Доказ. Перегляд backend/test/image.png (фото людей).

Вплив. Обмежений; див. опис.

Рекомендація. Замінити синтетичними зображеннями (як frontend/integration_tests/images/generate.mjs) або нейтральними патернами; переоцінити для банку.

Info

Info VIS-SEC-039 Образи не містять LICENSE і NOTICE (Apache-2.0 §4(a),(d))

CWE / OWASP	CWE-1104 · n/a
Компонент / тип	infra · process · зусилля S · впевненість High

Місце	`backend/Dockerfile`
	`backend/prisma/Dockerfile`
	`frontend/Dockerfile`

Опис. Vision — похідний твір від Visual Regression Tracker (Apache-2.0). Docker-образи не включають LICENSE і NOTICE. При передачі образів/коду компанії (навіть без продажу) Apache-2.0 §4(a),(d) вимагає зберегти LICENSE і NOTICE у кожній копії.

Доказ. Dockerfile-и не копіюють LICENSE/NOTICE в образ.

Вплив. Невідповідність умовам Apache-2.0 при передачі образів іншій особі/компанії (див. розділ 2.8 звіту).

Рекомендація. COPY LICENSE NOTICE в кожен образ і в jar SDK; зберегти copyright-заголовки upstream і примітку про зміни в NOTICE.

Пов’язано	NOTICE, ADR-0027

Info VIS-SEC-040 JWT без явного алгоритму, issuer і audience

CWE / OWASP	CWE-345 · A07:2021-Identification and Authentication Failures
Компонент / тип	backend · code · зусилля S · впевненість Medium
Місце	`backend/src/auth`

Опис. Перевірка JWT не задає явно `algorithms`, `issuer`, `audience`. Ризик низький (секрет симетричний, alg=none у @nestjs/jwt не проходить), але явне задання — захист на майбутнє.

Доказ. Конфіг JwtModule без algorithms/issuer/audience.

Вплив. Захист глибини; прямої вразливості не підтверджено.

Рекомендація. Задати `algorithms:['HS256']`, issuer, audience при verify.

Info VIS-SEC-041 Editor може змінювати налаштування й видаляти будь-який доступний проєкт (зокрема ключ Gemini)

CWE / OWASP	CWE-284 · A01:2021-Broken Access Control
Компонент / тип	backend · code · зусилля M · впевненість High
Місце	`backend/src/projects/projects.controller.ts:134,151`

Опис. Роль editor (глобальна, 042) може через PUT /projects і DELETE /projects/:id змінювати jiraUrl, ключ Gemini, назву й видаляти будь-який доступний проєкт. Узгоджується з глобальною рольовою моделлю 042, але варте рішення власника для банку (немає ролі «лише свій проєкт»).

Доказ. projects.controller.ts:134,151 (admin,editor).

Вплив. Editor однієї команди впливає на налаштування проєктів інших команд, до яких має доступ.

Рекомендація. Розглянути права на рівні проєкту (owner) поверх глобальних ролей. Потребує специфікації.

Пов’язано	спека 042

7. Дані за межами контуру та LLM

Повна таблиця — у `audit/raw/data-egress.md`. Нижче — що саме залишає контур і як це вимкнути.

Критичне для банку — автоматичний вихід при прийомі знімка (VIS-SEC-003). Якщо в налаштуваннях проєкту обрано рушій порівняння `vlm`, то `POST /test-runs` синхронно надсилає в Gemini (або в Ollama за `OLLAMA_BASE_URL`) три повні PNG — базову лінію, новий знімок і diff. Це вмикає будь-який editor проєкту; `AI_PROVIDER=none` на це не впливає, вимикача рівня інстансу немає. Типово рушій — `pixelmatch` (вихід вимкнено), але одного налаштування проєкту досить, щоб екрани банку пішли в Google без участі людини.

На вимогу (кнопки в рев'ю). Чернетки багів і підсумки груп змін надсилають у Gemini вирізки знімків і тексти екранів — ключем інстансу (`AI_PROVIDER=gemini`) або **особистим** ключем користувача (останнє `AI_PROVIDER=none` не вимикає, ADR-0020).

Jira. Особистий токен і вкладення-скриншоти йдуть на `jiraUrl` проєкту. Перевіряється лише hostname — проходять `http://`, інші порти й редиректи (VIS-SEC-008).

Google Drive. Бекап (тексти екранів, email, токени публічних звітів) вивантажується без шифрування (VIS-SEC-013, ADR-0012).

Як вимкнути вихід даних для банку (рекомендація):

- жорсткий вимикач рівня інстансу для всього зовнішнього AI (VLM-рушій + особисті/проєктні ключі), типово **off** у контурі (VIS-SEC-003, 016);
- `VISION_JIRA_HOSTS` — лише внутрішні Jira по `https`, без редиректів (VIS-SEC-008);
- бекап — лише у внутрішнє сховище або з шифруванням; вимкнути Google Drive (VIS-SEC-013);
- мережеву політику контуру налаштувати так, щоб `generativelanguage.googleapis.com`, `oauth2.googleapis.com`, `www.googleapis.com` були недосяжні, якщо зовнішній AI і Drive не погоджені ІБ.

8. Комерційне використання та ліцензії

Контекст. Автор розробив Vision самостійно й передає його своїй компанії для внутрішнього використання, без продажу. Навіть без продажу передача копії коду/образів від фізособи компанії — це розповсюдження в сенсі Apache-2.0, тож обов'язки §4(a),(c),(d) діють. Висновки нижче — контрольні питання, не юридичний висновок; остаточну оцінку має дати юрист; окремо варто зафіксувати, кому належать права на код і на яких умовах він передається компанії.

Власний код і атрибуція — гаразд. `LICENSE` (Apache-2.0) і `NOTICE` є в корені й у кожному пакеті; `NOTICE` містить примітку про похідність від Visual Regression Tracker і про зміни (§4(b)). Назва/бренд «Visual Regression Tracker» у коді, UI та i18n не використовується — лише в `LICENSE`/`NOTICE` та в коментарях про робочий VRT (§6 ліцензії дотримано). Jar SDK у дереві немає (L-3 закрито); чужих туторіал-скриншотів у `public/` немає (L-2 значною мірою закрито).

Єдиний недолік атрибуції: `LICENSE` і `NOTICE` **не копіюються в Docker-образи** та в jar SDK (VIS-SEC-039). При передачі образів компанії це слід виправити — `COPY LICENSE NOTICE` у кожен образ і в jar.

Ліцензії залежностей — усі пермісивні. Прод-залежності: 452 (backend) і 183 (frontend) пакети — MIT, Apache-2.0, ISC, BSD, BlueOak, OFL (шрифти), PSF (`argparse`), Unlicense (`postgres`, `robust-predicates`). Copyleft у поставку не потрапляє: єдиний EPL-2.0 (`elkjs`, через Prisma Studio) вирізається при збірці образів (`backend/Dockerfile:28-29`, `backend/prisma/Dockerfile:20`) — це **false positive** сканера для готового образу. `jszip` береться за MIT (подвійна MIT/GPL). MPL/CC-BY — лише в dev. Збігається з переліком попереднього аудиту.

Персональні й банківські дані. На екранах можуть бути ПІБ, номери карток/рахунків, баланси (персональні дані за Законом України «Про захист персональних даних»; якщо є номери карток — у полі зору PCI DSS). Контрольні питання для юриста/ІБ: мінімізація й строки зберігання знімків і UI-дерев; повне видалення проєкту/користувача разом із файлами й бекапами; аудит-лог дій адміністраторів (журнал рішень ADR-0014 покриває рішення щодо проблем, але не вхід, зміну ролей, доступ до знімків); вимоги НБУ до інформаційної безпеки банків. Окрема увага — VIS-SEC-003 і 013 (вихід банківських даних назовні) та VIS-SEC-042 (фото реальних людей у тестових фікстурах).

Шифрування. At rest: секрети в БД — AES-256-GCM (044); знімки в `imageUploads` і бекап у Drive — **без шифрування** (VIS-SEC-013). In transit: nginx TLS у поставці не налаштований (VIS-SEC-011); API↔Postgres/Redis — без TLS у compose.

9. Roadmap виправлень

Позначка **[спец]** — змінює поведінку, потрібна специфікація (цикл `/spec`); **[міг]** — потрібна лише додавальна міграція (ADR-0003).

До перенесення в контур (блокери):

Знахідка	Дія	Примітка
VIS-SEC-001	`ValidationPipe({whitelist,forbidNonWhitelisted,transform})`; `ModifyBuildDto` — клас	S
VIS-SEC-002	Відмова стартувати зі слабким/спільним із продом секретом	S
VIS-SEC-003, 016	Жорсткий вимикач зовнішнього AI на рівні інстансу, типово off	[спец]
VIS-SEC-004, 005, 014, 015	Аналіз/порівняння у воркер із тайм-аутом; межі розмірів і координат	[спец]
VIS-SEC-006, 007	LDAP: прив’язка за незмінним ID, відхилення порожнього пароля	[спец]
VIS-SEC-011	CSP + HSTS; TLS-термінація в поставці	M
VIS-SEC-008, 013	Jira лише https без редиректів; бекап без Google Drive або з шифруванням	S/M

30 днів: VIS-SEC-009 (відкликання сесій, [спец]+[міг]), 010, 012, 017 ([спец]), 018, 019, 020, 021; аудит-лог безпеки (вхід, зміна ролей, ключі, доступ до знімків).

90 днів: решта Low/Info; переоцінка рішень S-12/S-13/S-14 для банку; ротація секретів; політика сесій; процедура реагування на інциденти; прогін образів сканером банку (`trivy image`/Grype).

10. Додатки

10.1. Результати сканерів (агреговано)

Сканер	Результат	Висновок
npm audit (prod+dev, 3 пакети)	0 / 0 / 0	підтверджує «npm audit = 0» попереднього аудиту
osv-scanner (3 lock-файли, 2306 пакетів)	0 вразливостей	—
trivy fs (vuln, усе дерево)	0 вразливостей	збігається з npm/osv
trivy config (IaC)	3×LOW (немає HEALTHCHECK)	інформаційно
trivy license	1×MEDIUM EPL-2.0 `elkjs`	**FP**: вирізається при збірці образу
semgrep (локальні правила)	~1150 спрацювань, з них безпекових одиниці	решта — i18n/стиль; TP зведені в знахідки
bandit (CLI)	subprocess/urlopen	VIS-SEC-028 (apiKey при редиректі); решта — прийнятно
shellcheck	2 error (SC2148), кілька warning	стиль; у знахідки увійшло VIS-SEC-038
hadolint	info/warning (user-id, pin apt)	дрібне; не блокер
gitleaks (файли)	5 спрацювань	**усі FP**: тестові фікстури й приклади в README
license-checker	усе пермісивне	див. розділ 8

Розбір false positive (ключові): EPL-2.0 `elkjs` — вирізається при збірці (розділ 8); 5 спрацювань gitleaks — `NEWKEY…`/`eyJ…`/`F5Z2…` у `integration_tests` і `sdk-java/README.md` — тестові/приклади, не живі секрети; ~960 спрацювань semgrep `i18next-key-format` і `jsx-not-internationalized` — стиль інтернаціоналізації, не безпека.

10.2. SBOM

`audit/sbom.cdx.json` (CycloneDX, syft): 810 компонентів (802 npm, 1 maven, 2 github-actions, 5 файлів). Maven-граф неповний через обмеження мережі (див. розділ 2).

10.3. Перевірені й не перевірені області

Перевірено: усі 87 HTTP-маршрутів (guard/ролі/доступ до проєкту — `audit/raw/endpoints.md`), socket.io, прийом знімка й дерева, порівняння, звіти доступності, Jira, AI/VLM, бекапи, публічні звіти, CLI/MCP, автентифікація (JWT/LDAP/OIDC/API-ключі), секрети at rest, Dockerfile/compose/nginx/ CI, скрипти хоста, `.claude/hooks`, ліцензії та SBOM.

Не перевірено (обмеження): історія git; пакети ОС в образах (`trivy image`); runtime-ізоляція контейнерів і ліміти compose; повний транзитивний граф Gradle; поведінка LDAP/OIDC на живому каталозі; контрольна сума `gradle-wrapper.jar` проти офіційної.